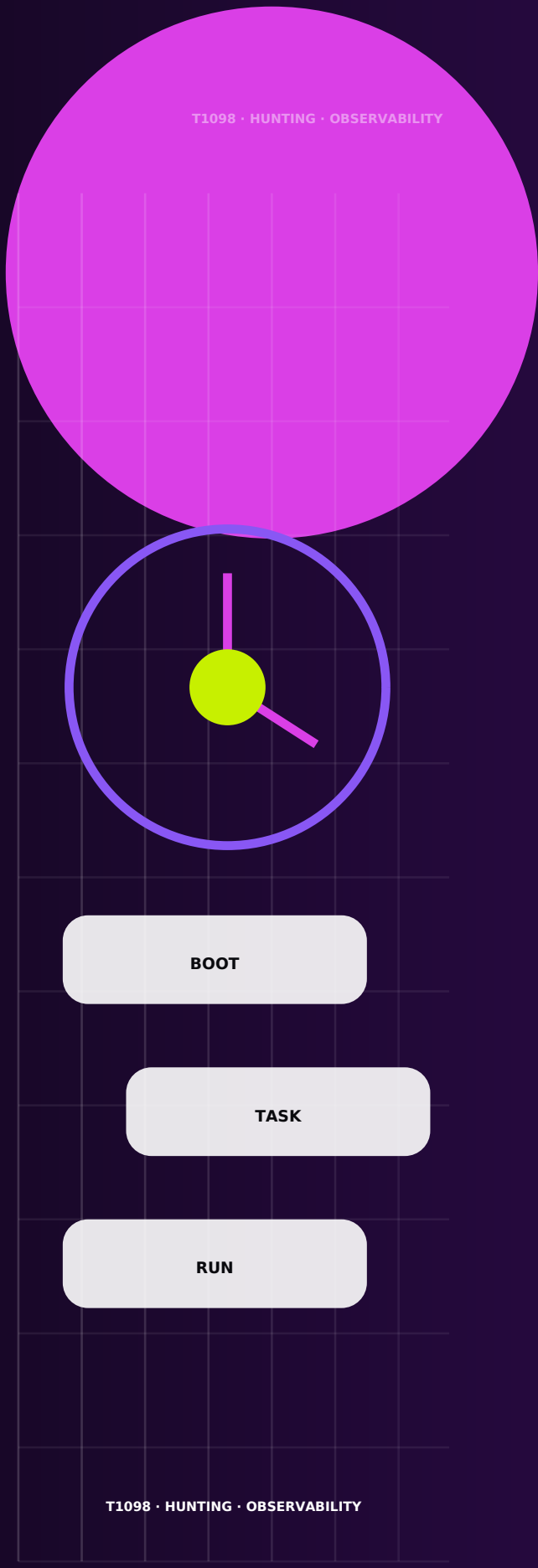
ZIMREAPER - ZIMBRA APP PASSWORD PERSISTENCE

A raw-audit hunting model for attacker created application passwords that bypass mailbox two-factor authentication.



HUNTING QUERY

CONFIDENCE: MEDIUM

REPORT TYPE
campaign

STATUS
Untested implementation sketch

PRIMARY PLATFORM
Splunk

OPERATIONAL VALUE
9 / 10

01

Executive Assessment

Decision-grade summary with explicit evidence boundaries.

ASSESSMENT

DECISION

Retain this package as a hunting query and migrate it to the canonical visual and evidence contract without changing query conditions. Treat every result as an investigative lead until local schema, field population, benign overlap and the legacy claim provenance are reviewed.

LEGACY EVIDENCE RECORD

- The retained legacy source ledger contains 3 normalized references; claim-to-source mapping remains...

ANALYST ASSESSMENT

- The existing logic is retained at hunting maturity; repository migration is not execution eviden...
- The folder and query header map the package to T1098; operational relevance still depends on local...

DETECTION ASSUMPTIONS

- The named telemetry is collected across the intended asset or identity scope with adequate...
- Projected fields preserve their expected semantics in the target connector and parser. [C002]
- Approved activity, owners and change records are available to analysts during disposition. [C003]

KEY FINDINGS

FINDING 1

The original query conditions and source ledger were preserved during layout migration; legacy PDF SHA-256 0ed2b4d053fe71be... is recorded for traceability. [C001]

FINDING 2

The principal observable is Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected investigation context. [C002]

FINDING 3

The evidence boundary remains explicit: a match does not prove successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corroborating evidence. [C003]

EVIDENCE BOUNDARY

A matching result does not prove successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corroborating evidence. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

02

Threat Mechanics

Technical mechanism, observable transitions and supported scope.

ATTACK FLOW

TECHNICAL BACKGROUND

The retained dossier links Zimreaper to the detection opportunity described as zimbra app password persistence. The v2 migration preserves the query exactly and exposes its match boundary, but does not reinterpret legacy source claims as laboratory evidence. Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected investigation context. [C001][C002]

1

THREAT CONTEXT

A raw-audit hunting model for attacker created application passwords that bypass mailbox two-factor authentication. Observable: Context retained from the legacy dossier and source ledger.

2

OBSERVABLE CANDIDATE

Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected investigation context. Observable: Events from the primary query source and projected fields.

3

CONTEXTUAL ENRICHMENT

Resolve asset, identity, process, ownership and change context before disposition. Observable: Raw event, surrounding timeline, inventory and authorized-change evidence.

4

DECISION GATE

Escalate only when corroborating evidence closes the documented non-claim boundary. Observable: Controlled validation, explainable negatives and analyst-readable evidence.

03

Telemetry & Evidence Model

Minimum data contract and known visibility gaps.

DATA CONTRACT

PRIMARY PLATFORM

Splunk. Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected investigation context.

FIELD / TABLE	STATUS	PURPOSE
Primary event source	**Required**	Resolve the query source against the local connector and parser.
Event time and entity identifiers	**Required**	Chronology, deduplication, scoping and investigation pivots.
Raw projected context	**Required**	Preserve the fields emitted by the query before normalization or tuning.
Asset, identity and change inventory	**Enrichment**	Separate authorized activity and define operational ownership.

KNOWN VISIBILITY GAPS

Unvalidated local schema Missing projected fields Incomplete retention or asset scope Mutable attacker behavior Legacy claim provenance review pending

04

Primary Detection Logic

Native query, explicit condition evidence and match meaning.

SPL

```
# Rule: [T1098] Zimreaper - Zimbra App Password Persistence
# MITRE ATT&CK: T1098
# Classification: Hunting query
# Status: Untested implementation sketch
# Primary platform: Splunk
# Required telemetry: See query body and local connector contract
# Purpose: A raw-audit hunting model for attacker created application passwords that bypass mailbox two-factor authentication.
# Logic: Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected i
# A match proves: A result proves that the published query conditions matched in the named telemetry; it is an investigative event, not a malicious
# A match does not prove: successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corr
# Expected false positives: authorized administration, approved software, testing, or benign artifact collisions.
# Coverage limits: local schema, field population, retention, collection scope, and attacker variation require validation.
# Evidence claims: C001, C002, C003
#
index=<CUSTOMER_INDEX> source="/opt/zimbra/log/audit.log"
("CreateAppSpecificPassword" OR "CreateAppSpecificPasswordRequest")
"ZimbraWeb"
| table _time host source sourcetype _raw
```

WHAT A MATCH PROVES

A result proves that the published query conditions matched in the named telemetry; it is an investigative event, not a malicious verdict.

WHAT IT DOES NOT PROVE

successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corroborating evidence.

MATURITY

Hunting query - Untested implementation sketch. Evaluate the named telemetry for zimbra app password persistence using the existing source-derived conditions while preserving projected investigation context.

05

Triage & Hunting Playbook

Evidence-preserving workflow from match to disposition.

WORKFLOW

01

Preserve the complete raw matching event, query version, timestamp, connector or sensor version and stable entity identifiers.

02

Confirm the event originated from the intended Splunk data source and verify the semantics of every condition used by the query.

03

Resolve asset, identity, process, software and destination ownership against authoritative inventories and approved change records.

04

Build the surrounding endpoint, identity, network or appliance timeline and seek an independent evidence layer before escalation.

05

Classify benign overlap explicitly; tune only with durable ownership or provenance controls, never by suppressing the core behavior globally.

06

Escalate only when corroborating evidence establishes malicious or unauthorized activity beyond the documented match boundary.

DISPOSITION RULE

Escalate only when the evidence establishes the behavior described by the query. successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corroborating evidence.

06

False Positives & Validation

Overlap model, controlled checks and promotion gate.

QUALITY GATE

AUTHORIZED ADMINISTRATION OR SOFTWARE

Require owner, purpose, approved change and expected execution or configuration provenance.

BENIGN ARTIFACT OR COMMAND COLLISION

Require the full condition set plus an independent evidence layer or stable provenance.

PARSER, INVENTORY OR RETENTION AMBIGUITY

Reproduce a controlled event and reconcile raw fields, collection scope and authoritative inventory.

VALIDATION SEQUENCE

- Generate an authorized controlled equivalent of the primary observable without using live malicious infrastructure.
- Verify each query condition and projected field against retained raw telemetry.
- Run representative approved and near-match negative controls.
- Measure historical prevalence and classify every returned owner or workflow.
- Record parser, connector, retention and asset-scope dependencies with the test evidence.

SUCCESS

The controlled positive produces a complete, explainable row and representative negatives are separable through durable context.

REJECTION

Reject promotion when field semantics, collection scope, benign ownership or the core behavior cannot be established reproducibly.

PROMOTION GATE

Require claim-level source review, a retained controlled positive, representative negatives, measured prevalence and an accountable operational owner.

07

Analyst Assessment & References

Coverage statement, open questions and source record.

FINAL

CONCLUSION

This package now uses the canonical v2 layout and evidence contract while preserving the original hunting.spl conditions. It remains a hunting query at medium confidence. The visual migration is complete; claim-level provenance and target-environment execution remain explicit promotion gates.

MITRE ATT&CK

T1098

PRIMARY AND AUTHORITATIVE REFERENCES

S001 proofpoint.com - Observed campaign period: 2025-07 through 2026-02 (2026-07-23)

hxxps://www[.]proofpoint[.]com/us/blog/threat-insight/ta488-targets-zimbra-mailservers-half-click-exploits

S002 help.splunk.com - Splunk Enterprise - search command (2026-07-24)

hxxps://help[.]splunk[.]com/en/splunk-enterprise/spl-search-reference/9[.]0/search-commands/search

S003 MITRE ATT&CK - T1098 - Account Manipulation (2026-07-24)

hxxps://attack[.]mitre[.]org/techniques/T1098/

OPEN QUESTIONS

A matching result does not prove successful exploitation, malicious ownership, downstream impact, campaign attribution or complete compromise without corroborating evidence. Target-environment field population, benign prevalence, parser behavior and operational ownership have not been validated by this repository migration.

DOCUMENT CONTROL

Schema 2.0 | Layout 2.0 | Maturity hunting | Confidence Medium | No customer data | Evidence ledger required